

ROAD TO HALL OF FAME - ACTIVIDAD 09
**LAB: FILE PATH TRAVERSAL, TRAVERSAL
SEQUENCES STRIPPED NON-RECURSIVELY**

Mtro. Servando López Contreras

Informe realizado por:

181583 Angel Aaron Acuña Quezada

Contenido

Datos del Laboratorio	3
Marco Teórico y Fundamentación Técnica	3
Procedimiento	4
Explicación del Payload	7
Mitigación Recomendada.....	8
Referencias	8

Datos del Laboratorio

- **Nombre del laboratorio:** File path traversal, traversal sequences stripped non-recursively
- **Nivel:** Practitioner
- **Tipo de Explotación:** File Path Traversal
- **Objetivo del laboratorio:** Explorar la vulnerabilidad de File Path Traversal a través del método de petición "GET" del protocolo HTTP, con el fin de poder leer el archivo `/etc/passwd`.

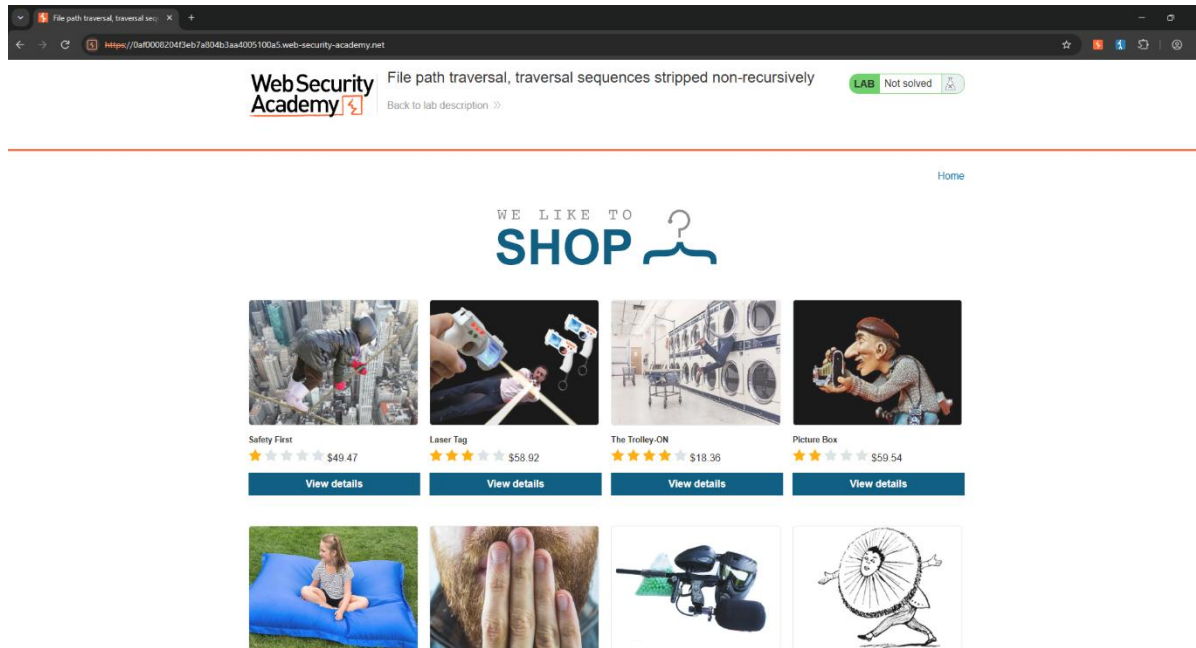
Marco Teórico y Fundamentación Técnica

Concepto: De acuerdo con OWASP, un ataque de *Path Traversal* (también conocido como *Directory Traversal*) tiene como objetivo acceder a archivos y directorios que están almacenados fuera de la carpeta raíz web. Al manipular las variables que hacen referencia a los archivos usando secuencias de "punto-punto-barra" (`../`) o rutas absolutas permite a un atacante acceder a archivos y directorios en el sistema de archivos, incluyendo código fuente de la aplicación, configuraciones y archivos críticos del sistema. En el caso particular de este laboratorio, la aplicación elimina las secuencias de traversal (`../`) de la entrada del usuario, pero lo hace de forma **no recursiva** (es decir, en una sola pasada). Esto permite evadir el filtro colocando secuencias anidadas como `....//`, ya que al quitarle una sola vez el patrón `../` del centro, lo que queda es exactamente `../`, reconstruyendo la secuencia de traversal después del filtrado.

Impacto en la Triada CIA: Esta vulnerabilidad compromete de manera directa la "Confidencialidad" de la información, ya que expone datos sensibles del sistema operativo.

Perspectiva OWASP: Clasificada dentro de la categoría de *Broken Access Control* (Control de Acceso Roto), ocurre cuando la aplicación utiliza la entrada del usuario para construir una ruta de archivo sin validar o sanear adecuadamente dicha entrada, permitiendo escapar de la estructura de directorios autorizada.

Procedimiento



Se ingresó a la tienda virtual del laboratorio, en la cual podemos ver que carga varias imágenes de productos.

1. Live passive crawl from Proxy (all traffic)

Summary

Items added to site map [View site map](#)

Host	Method	URL	Status co...	MIME type
0af0008204f3eb7a80...	GET	/	200	HTML
0af0008204f3eb7a80...	GET	/resources/labheader/css/academ...	200	CSS
0af0008204f3eb7a80...	GET	/resources/css/labsEcommerce.css	200	CSS
0af0008204f3eb7a80...	GET	/resources/labheader/js/labHead...	200	script
0af0008204f3eb7a80...	GET	/resources/images/shop.svg	200	XML
0af0008204f3eb7a80...	GET	/image?filename=61.jpg	200	
0af0008204f3eb7a80...	GET	/resources/images/rating1.png	200	PNG
0af0008204f3eb7a80...	GET	/product?productid=1		
0af0008204f3eb7a80...	GET	/image?filename=63.jpg	200	
0af0008204f3eb7a80...	GET	/resources/images/rating3.png	200	PNG
0af0008204f3eb7a80...	GET	/product?productid=2		
0af0008204f3eb7a80...	GET	/image?filename=27.jpg	200	
0af0008204f3eb7a80...	GET	/resources/images/rating4.png	200	PNG
0af0008204f3eb7a80...	GET	/product?productid=3		
0af0008204f3eb7a80...	GET	/image?filename=17.jpg	200	
0af0008204f3eb7a80...	GET	/resources/images/rating2.png	200	PNG
0af0008204f3eb7a80...	GET	/product?productid=4		
0af0008204f3eb7a80...	GET	/image?filename=30.jpg	200	
0af0008204f3eb7a80...	GET	/product?productid=5		
0af0008204f3eb7a80...	GET	/image?filename=4.jpg	200	
0af0008204f3eb7a80...	GET	/product?productid=6		
0af0008204f3eb7a80...	GET	/image?filename=39.jpg	200	
0af0008204f3eb7a80...	GET	/product?productid=7		
0af0008204f3eb7a80...	GET	/image?filename=28.jpg	200	
0af0008204f3eb7a80...	GET	/product?productid=8		

Task configuration [View configuration](#)

Task type: Live passive crawl
 Scope: Proxy (all traffic)
 Configuration: Add links. Add item itself, same domain and URLs in suite scope.
 Capturing: ☒

Task progress

Site map items added: 53
 Responses processed: 33
 Responses queued: 0

Task log

- > Adding response https://0af0008204f3eb7a804b3aa4005100a5.web-security-academy.net/favicon.ico to site map
- > Adding response https://0af0008204f3eb7a804b3aa4005100a5.web-security-academy.net/academyHeader to site map
- > Adding response https://0af0008204f3eb7a804b3aa4005100a5.web-security-academy.net/resources/labheader/images/logoAcademy.svg to site map
- > Adding response https://0af0008204f3eb7a804b3aa4005100a5.web-security-academy.net/resources/labheader/images/ps-lab-notsolved.svg to site map

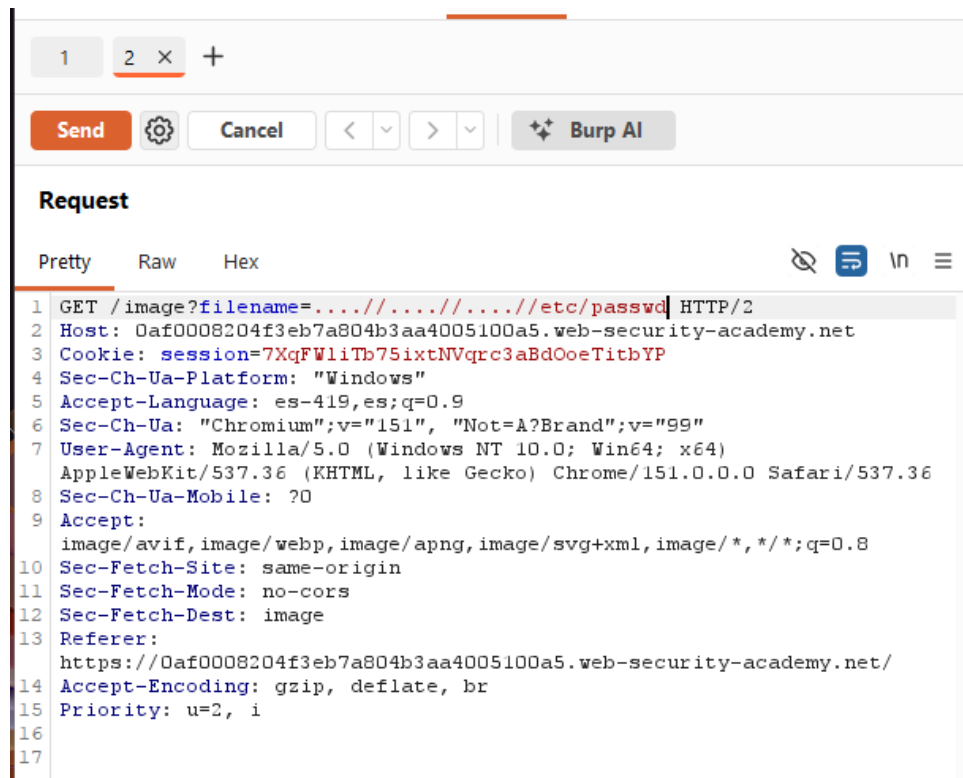
Memory: 136.5MB of 15.91GB ☒ Disabled

The screenshot displays the Burp Suite interface. The top menu bar includes Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Logger, Organizer, Extensions, and Discover. The main window is divided into several panes. The top pane shows the HTTP history tab with a list of requests. A filter settings dialog is open, allowing users to filter requests by request type, MIME type, status code, search term, file extension, annotation, and listener. The dialog is configured to show only image files (MIME type: Images) and to filter by status code 2xx (success). The main window shows a list of HTTP requests, including a GET request to /image. The bottom panel shows the request and response details for the selected request.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener
1	https://0af0008204f3eb7a80...	GET	/			200	10585	HTML		File path traversal, tra...		✓	34.246.129.62	session=7XqFWL...	22:40:07 23 ...	8080
32	https://0af0008204f3eb7a80...	GET	/academyLabHeader			101	147					✓	34.246.129.62		22:40:08 23 ...	8080
34	https://0af0008204f3eb7a80...	GET	/product?productId=1			200	4441	HTML		File path traversal, tra...		✓	34.246.129.62		22:54:16 23 ...	8080
35	https://0af0008204f3eb7a80...	GET	/product?productId=2			200	3860	HTML		File path traversal, tra...		✓	34.246.129.62		22:54:33 23 ...	8080
36	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:54:36 23 ...	8080
37	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:54:37 23 ...	8080
38	https://0af0008204f3eb7a80...	GET	/									✗	34.246.129.62		22:54:44 23 ...	8080
57	https://0af0008204f3eb7a80...	GET	/academy									✗	34.246.129.62		22:54:49 23 ...	8080
71	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:55:01 23 ...	8080
75	https://0af0008204f3eb7a80...	GET	/academy									✗	34.246.129.62		22:55:03 23 ...	8080
76	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:55:03 23 ...	8080
80	https://0af0008204f3eb7a80...	GET	/academy									✗	34.246.129.62		22:55:32 23 ...	8080
81	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:55:32 23 ...	8080
89	https://0af0008204f3eb7a80...	GET	/academy									✗	34.246.129.62		22:56:17 23 ...	8080
90	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:57:11 23 ...	8080
91	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:57:17 23 ...	8080
99	https://0af0008204f3eb7a80...	GET	/academy									✗	34.246.129.62		22:57:47 23 ...	8080
100	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:58:05 23 ...	8080
101	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:58:06 23 ...	8080
102	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:58:10 23 ...	8080
103	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:58:13 23 ...	8080
104	https://0af0008204f3eb7a80...	GET	/product?									✗	34.246.129.62		22:58:23 23 ...	8080

The bottom panel shows the request and response details for the selected request. The request is a GET request to /image. The response is a 200 OK response with Content-Type: text/html; charset=utf-8. The response body contains HTML content.

Durante la fase de reconocimiento en Burp Suite, se identificó un patrón inseguro en las peticiones GET hacia /image. La aplicación emplea el parámetro filename para la carga de recursos. Este parámetro se convierte en un vector ideal para inyectar salto de directorio. Para poder visualizar estas peticiones en el HTTP history, fue necesario ajustar el filtro y habilitar la casilla 'Images' dentro de 'Filter by MIME type', ya que por defecto estaba desmarcada y ocultaba las peticiones hacia recursos de tipo imagen, incluyendo las que utilizan el parámetro filename.



Haciendo un análisis rápido podemos ver que el método GET directamente llama a las imágenes, así que intentaremos atacar a través de ellas. Para esto, enviamos la petición al 'Repeater' y preparamos el payload utilizando secuencias de traversal anidadas://....//....//etc/passwd. A diferencia del caso anterior, aquí la aplicación sí elimina las secuencias ../ de la entrada, pero lo hace de forma no recursiva; al quitar el patrón central de cada bloque//, los caracteres restantes se recombinan formando nuevamente ../, reconstruyendo así el traversal después del filtrado.

The screenshot shows the Burp Suite interface with a target URL of `https://0af0008204f3eb7a8041`. The 'Request' tab is active, displaying an HTTP GET request to `/image?filename=../.../etc/passwd`. The request includes headers such as `Host: 0af0008204f3eb7a8041005100a5.web-security-academy.net`, `Cookie: session=7XqFW1i7b75ixtNVqrc3aBd0oeT1tbYP`, and `Accept-Language: es-419,es;q=0.9`. The 'Response' tab shows a 200 OK status with a `Content-Type: image/jpeg` and a `Content-Length: 2316`. The response body contains a list of system users and their home directories, such as `root:x:0:0:root:/root:/bin/bash` and `daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin`.

Damos clic en "Send" y podemos observar que tuvimos éxito y tenemos acceso al archivo `passwd`.

Explicación del Payload

El parámetro `filename` indica al servidor qué archivo leer del disco duro. En este laboratorio, la aplicación intenta defenderse eliminando las secuencias de traversal (`../`) que detecta en la entrada del usuario, pero realiza esta operación de forma **no recursiva**, es decir, la ejecuta una sola vez sobre la cadena completa sin volver a revisarla después de aplicar el filtro. Esto permite construir un payload con secuencias anidadas: `../.../.../etc/passwd`. Al eliminar el patrón `../` que se encuentra intercalado en cada bloque `../...`, los caracteres que quedan a los lados se recombinan y forman nuevamente la secuencia `../`, reconstruyendo así el path traversal que en principio había sido bloqueado. Como el servidor no vuelve a analizar la cadena resultante tras el filtrado, el ascenso de directorios se completa sin problema, permitiendo salir de la carpeta raíz web y llegar hasta `/etc/passwd`.

Mitigación Recomendada

- **Evitar entradas directas:** Lo más efectivo es evitar, lo más que se pueda, pasar la entrada directa al sistema de archivos. En su lugar, se podrían usar identificadores en una base de datos para localizar un archivo.
- **Sanitización iterativa:** El error ocurre porque el filtro elimina las secuencias ../ una sola vez, sin verificar si al hacerlo se formó una nueva secuencia peligrosa. Por eso, la corrección correcta es que el filtro se aplique de manera recursiva, revisando la cadena una y otra vez hasta que ya no queden coincidencias, en lugar de ejecutarse solo una vez. Una alternativa aún más segura es que la aplicación **rechace por completo** cualquier entrada que contenga el patrón ../, en vez de intentar corregirla y seguir procesándola.
- **Rutas Absolutas:** Tras recibir la entrada, la aplicación debe anexarla al directorio base estricto y utilizar funciones de canonicalización provistas por el lenguaje de programación (ej. `realpath()` o `os.path.abspath()`). Finalmente, el sistema debe verificar de forma rigurosa que la ruta absoluta resultante comience exactamente con el directorio base autorizado antes de proceder con la lectura del archivo.

Referencias

OWASP. (s.f.). *Path Traversal*. OWASP Community. Recuperado el 24 de septiembre de 2026, de https://community.owasp.org/attacks/Path_Traversal